

IFCT0109 · Seguridad Informática

MF0486_3 · Seguridad en Equipos Informáticos

Cuaderno de Prácticas

UD1: Fundamentos de Seguridad y Gestión del Riesgo

Nombre y apellidos	
Grupo / Turno	
Fecha de entrega	

Instrucciones generales

Lee el enunciado de cada actividad con atención antes de responder. Justifica siempre tus decisiones citando la normativa o metodología correspondiente (ENS RD 311/2022, MAGERIT v3, RGPD). Las tablas de respuesta se rellenan directamente en este documento. Las respuestas abiertas deben ser razonadas, no monosilábicas.

Este cuaderno cubre la Capacidad C1 del MF0486_3: analizar planes de implantación, identificar sistemas y niveles de seguridad, describir medidas y cumplimentar formularios de protección de datos.

Actividades de la Unidad

Actividad	Título	Tipo	Valoración
ACT-01	Clasificación de amenazas y salvaguardas	Teórica	15 puntos
ACT-02	Ciclo PDCA aplicado a un SGSI	Análisis	15 puntos
ACT-03	Marco normativo — preguntas de aplicación	Teórica	10 puntos
ACT-04	BIA — Empresa de servicios digitales	Caso práctico	20 puntos
ACT-05	Análisis de riesgos con MAGERIT v3	Caso práctico	25 puntos
ACT-06	Matriz de riesgo y tratamiento	Análisis	10 puntos
ACT-07	Supuesto integrador — Plan de implantación	Integrador	25 puntos

ACT-01 Clasificación de amenazas y salvaguardas

Capacidad: C1 / CE1.2 | **Tipo:** Individual | **Duración:** 45 min

Enunciado

A continuación, se presentan 12 eventos de seguridad. Para cada uno debes:

- Identificar el tipo de amenaza (deliberada, accidental, desastre natural, fallo técnico).
- Indicar qué dimensión o dimensiones de la tríada CIA se ven afectadas (C, I, A).
- Proponer la salvaguarda técnica más adecuada.
- Proponer la salvaguarda organizativa más adecuada.

Consulta el catálogo de amenazas del Libro II de MAGERIT v3 para clasificar correctamente cada evento.

#	Evento de seguridad	Tipo amenaza	CIA afectada	Salvaguarda técnica	Salvaguarda organizativa
1	Un empleado reenvía por error a un cliente externo un informe interno confidencial.				
2	Un atacante externo lanza un ataque DDoS contra el servidor web de la empresa.				
3	Un incendio en la sala de servidores destruye los equipos de producción.				
4	Un empleado descontento borra registros de BBDD antes de abandonar la empresa.				
5	Fallo del disco duro de un servidor crítico sin copia de seguridad reciente.				
6	Un técnico de soporte externo accede a ficheros de RR.HH. sin autorización.				
7	Un ransomware cifra todos los documentos de la carpeta compartida.				
8	Corte eléctrico que deja fuera de servicio				

	el CPD durante 4 horas.				
9	Interceptación del tráfico de red interno mediante ARP spoofing.				
10	Actualización de software que introduce un bug que corrompe datos contables.				
11	Publicación accidental en el repositorio público de código con credenciales.				
12	Phishing dirigido (spear phishing) al director financiero.				

Reflexión final (respuesta libre)

De los 12 eventos anteriores, ¿cuál consideras que tendría mayor impacto en una empresa del sector sanitario que trata datos de pacientes? Justifica tu respuesta indicando qué dimensiones CIA se verían más afectadas y por qué.

ACT-02**Ciclo PDCA aplicado a un SGSI****Capacidad:** C1 / CE1.1 | **Tipo:** Individual | **Duración:** 30 min**Enunciado**

Lee el siguiente caso y responde a las preguntas que se plantean a continuación.

CASO: TechServ Solutions S.L. es una empresa de 80 empleados que presta servicios cloud a administraciones públicas. Tras sufrir una brecha de seguridad en la que se filtraron datos de 3.000 ciudadanos, la dirección encarga una auditoría. Los resultados revelan: (1) no existe política de seguridad documentada, (2) los empleados no reciben formación en ciberseguridad, (3) no hay análisis de riesgos formalizado, (4) los parches de seguridad se aplican con meses de retraso, y (5) no se realizan auditorías de acceso periódicas. La empresa tiene certificación ISO 9001 pero nunca ha implantado un SGSI.

Pregunta 1 — Diagnóstico por fases PDCA

Para cada deficiencia detectada en la auditoría, indica en qué fase del ciclo PDCA está fallando TechServ y qué acción correctiva propones:

Deficiencia detectada	Fase PDCA que falla	Acción correctiva propuesta
No existe política de seguridad documentada.		
Los empleados no reciben formación en ciberseguridad.		
No hay análisis de riesgos formalizado.		
Los parches se aplican con meses de retraso.		
No se realizan auditorías de acceso periódicas.		

Pregunta 2 — Hoja de ruta de implantación del SGSI

Ordena cronológicamente las 5 primeras acciones que debería tomar TechServ para iniciar la implantación de su SGSI según ISO/IEC 27001:2022 y el ENS (RD 311/2022). Justifica el orden propuesto.

Pregunta 3 — Responsabilidad normativa

¿Qué obligaciones tiene TechServ respecto a la brecha de datos ocurrida? Indica plazos, organismos a notificar y consecuencias potenciales citando la normativa aplicable (RGPD, LOPDGDD).

ACT-03**Marco normativo — preguntas de aplicación****Capacidad:** C1 / CE1.3 | **Tipo:** Individual | **Duración:** 30 min**Enunciado**

Responde a cada pregunta de forma concisa y razonada. Indica siempre el artículo o apartado normativo en el que basas tu respuesta.

Pregunta 1. Un ayuntamiento de 5.000 habitantes gestiona el padrón municipal y la plataforma de pago de impuestos con un único servidor. ¿En qué categoría ENS (Básico, Medio, Alto) clasificarías cada sistema y por qué?

Pregunta 2. ¿Cuándo es obligatorio realizar una DPIA (Evaluación de Impacto en Protección de Datos)? Pon dos ejemplos concretos en el contexto de una empresa de gestión de residuos que implanta videovigilancia en sus instalaciones.

Pregunta 3. Una empresa privada que presta servicios de nube a la Comunidad de Madrid ¿está obligada a cumplir el ENS? ¿Desde qué fecha necesita certificación? Cita el artículo correspondiente del RD 311/2022.

Pregunta 4. Describe las tres opciones que tiene una organización para tratar el riesgo residual según MAGERIT v3 y el ENS. Da un ejemplo práctico de cada una.

Pregunta 5. La Directiva NIS2 introduce el concepto de 'entidades esenciales' e 'entidades importantes'. Explica la diferencia y da dos ejemplos de cada tipo en el sector de la sanidad.

Pregunta 6. ¿Qué diferencia hay entre la notificación de una brecha de seguridad a la AEPD y la notificación a los interesados afectados según el RGPD? Indica los plazos de cada una.

Pregunta 7. Un CISO propone eliminar la contraseña de la cuenta de administrador del servidor de producción para facilitar el trabajo. ¿Qué principios de seguridad se vulnerarían? ¿Qué medidas alternativas propondrías?

ACT-04**Análisis de Impacto de Negocio (BIA)****Capacidad:** C1 / CE1.2 / CE1.4 | **Tipo:** Individual | **Duración:** 60 min**Enunciado — Empresa: Clínica Salud Digital S.A.**

Clínica Salud Digital S.A. es una clínica privada con 3 centros en Andalucía, 250 empleados y 80.000 pacientes registrados. Presta servicios médicos, facturación a aseguradoras y formación a personal sanitario. Quiere adecuarse al ENS y al RGPD como paso previo a concursar en licitaciones públicas.

A continuación se describen los 5 procesos de negocio principales de la organización:

Proceso	Nombre	Descripción
P-01	Historia Clínica Electrónica (HCE)	Registro, consulta y actualización de los historiales médicos de los 80.000 pacientes. Incluye diagnósticos, medicación, pruebas e imágenes médicas. Accedida 24/7 por médicos, enfermería y administrativos.
P-02	Facturación a aseguradoras	Emisión y seguimiento de facturas a 12 compañías aseguradoras. Procesa datos económicos y datos de salud para justificar prestaciones. Ciclo mensual de cierre.
P-03	Citas y agenda médica	Gestión de citas presenciales y telemáticas. Recordatorios automáticos por SMS/email. 500 citas/día entre los 3 centros.
P-04	Acceso a urgencias 24h	Sistema de triaje y registro de pacientes urgentes. Acceso desde dispositivos móviles del personal de guardia. Crítico en términos de disponibilidad.
P-05	Formación y e-learning	Plataforma de formación continua del personal sanitario. No contiene datos de pacientes. Uso en horario laboral. Sin impacto operativo si no está disponible 48h.

Tarea 1 — Valoración CIA de los procesos

Valora cada proceso en las tres dimensiones de seguridad (Confidencialidad, Integridad, Disponibilidad) usando la escala: BAJO / MEDIO / ALTO. Justifica brevemente cada valoración Alta.

Proceso	Confidencialidad	Justif. C	Integridad	Justif. I	Disponibilidad	Justif. D
P-01 HCE						
P-02 Facturación						
P-03 Citas						
P-04 Urgencias						
P-05 Formación						

Tarea 2 — Categoría ENS del sistema que soporta cada proceso

Determina la categoría ENS (Básico / Medio / Alto) del sistema de información que soporta cada proceso. Recuerda: la categoría del sistema es la dimensión más alta de entre C, I y A.

Proceso	Sistema de información	Categoría ENS	Justificación
P-01 HCE	Servidor HCE + BBDD pacientes		
P-02 Facturación	Sistema ERP + módulo facturación		
P-03 Citas	Plataforma de agenda + CRM		
P-04 Urgencias	App móvil + servidor de triaje		
P-05 Formación	Plataforma LMS (e-learning)		

Tarea 3 — RTO y RPO de los procesos críticos

Para los dos procesos que hayas valorado con mayor criticidad global, define el RTO y el RPO que consideras razonables. Justifica cada valor indicando las consecuencias que tendría superarlo.

Proceso	RTO propuesto	Consecuencia si se supera	RPO propuesto	Consecuencia si se supera

Tarea 4 — Necesidad de DPIA

¿Para cuál o cuáles de los 5 procesos es obligatorio realizar una Evaluación de Impacto (DPIA)? Justifica tu respuesta citando el artículo del RGPD y las guías de la AEPD que resulten aplicables.

ACT-05 Análisis de riesgos con MAGERIT v3

Capacidad: C1 / CE1.4 | **Tipo:** Individual / Parejas | **Duración:** 75 min

Enunciado — Ayuntamiento de Villanueva del Software

El Ayuntamiento de Villanueva del Software (15.000 habitantes) dispone de los siguientes activos de información. Tu tarea es aplicar el proceso de análisis de riesgos de MAGERIT v3.

ID	Activo	Descripción	Tipo MAGERIT	Propietario
A-01	Servidor padrón municipal	Servidor con BBDD de todos los residentes. Datos de nivel alto (RGPD). Acceso 24/7.	[SW] Aplicación + [HW] Servidor	Secretaría
A-02	Red WiFi municipal	Red inalámbrica en dependencias municipales. WPA2-Personal compartida. Sin segmentación.	[COM] Red	Informática
A-03	Plataforma de tramitación electrónica	Portal web de servicios al ciudadano. Certificado digital caducado hace 3 meses.	[SW] Aplicación web	Alcaldía
A-04	Portátiles del personal técnico	12 portátiles Windows 10 sin cifrado, sin MDM. Se usan para teletrabajo.	[HW] Equipos	RRHH
A-05	Correo corporativo	Exchange Server on-premise. Sin MFA. Usuarios con contraseñas de más de 2 años.	[SW] Servicio de correo	Informática
A-06	Copias de seguridad	Backup en disco externo en la misma sala de servidores. Sin copia offsite. Sin cifrar.	[AUX] Soporte de info.	Informática

Tarea 1 — Valoración de activos (dimensiones CIA + AT + T)

Valora cada activo en las 5 dimensiones del ENS/MAGERIT usando la escala: MB (muy bajo) / B (bajo) / M (medio) / A (alto) / MA (muy alto).

Activo	C	I	D	AT	T	Nivel global
A-01 Servidor padrón						
A-02 Red WiFi						
A-03 Tramitación web						
A-04 Portátiles						
A-05 Correo						
A-06 Copias de seguridad						

Tarea 2 — Identificación de amenazas (catálogo MAGERIT)

Para cada activo, identifica las 2 amenazas más relevantes usando el catálogo del Libro II de MAGERIT v3. Indica el código de amenaza (ej: [E.1], [A.5]...) y el nombre.

Activo	Amenaza 1 (código + nombre)	Amenaza 2 (código + nombre)
A-01 Servidor padrón		
A-02 Red WiFi		
A-03 Tramitación web		
A-04 Portátiles		
A-05 Correo		
A-06 Copias de seguridad		

Tarea 3 — Estimación del riesgo

Para cada par activo-amenaza de la tarea anterior, estima la probabilidad (1=Muy baja, 2=Baja, 3=Media, 4=Alta, 5=Muy alta) y el impacto (1-5) y calcula el nivel de riesgo (Probabilidad × Impacto). Clasifícalo como: BAJO (1-5), MEDIO (6-12), ALTO (13-19), CRÍTICO (20-25).

Activo	Amenaza	Probabilidad (1-5)	Impacto (1-5)	Riesgo (P×I)	Nivel
A-01	Amenaza 1				
A-01	Amenaza 2				
A-02	Amenaza 1				
A-02	Amenaza 2				
A-03	Amenaza 1				
A-03	Amenaza 2				
A-04	Amenaza 1				
A-04	Amenaza 2				
A-05	Amenaza 1				
A-05	Amenaza 2				
A-06	Amenaza 1				
A-06	Amenaza 2				

Tarea 4 — Plan de tratamiento del riesgo

Para los 3 riesgos con nivel más alto, propón la opción de tratamiento (mitigar / aceptar / transferir / evitar), la medida concreta y el plazo de implantación. Justifica por qué has elegido esa opción y no otra.

Riesgo (activo + amenaza)	Opción tratamiento	Medida concreta	Plazo	Justificación

ACT-06 Matriz de riesgo y decisiones de tratamiento

Capacidad: C1 / CE1.1 | Tipo: Individual | Duración: 30 min

Enunciado

Se te proporcionan 8 riesgos ya calculados de una empresa de logística con datos de clientes. Para cada riesgo:

- Ubícalo en la matriz de riesgo 5×5 usando las coordenadas (Probabilidad, Impacto).
- Clasifícalo en el nivel de riesgo correspondiente (BAJO / MEDIO / ALTO / CRÍTICO).
- Selecciona la opción de tratamiento más adecuada y justifícala en una frase.

#	Riesgo	P (1-5)	I (1-5)	P×I	Nivel	Tratamiento propuesto
R-01	Acceso no autorizado a BBDD de clientes por credenciales comprometidas.	4	5	20		
R-02	Fallo del servidor de backup en hora punta.	2	3	6		
R-03	Empleado que accede a datos fuera de su ámbito por exceso de permisos.	3	3	9		
R-04	Ataque ransomware que cifra todos los ficheros de la red.	3	5	15		
R-05	Pérdida de un portátil sin cifrado con datos de rutas y clientes.	2	4	8		
R-06	Correo phishing que captura credenciales de un operario.	4	4	16		
R-07	Caída del servidor web 2 horas en festivo.	2	2	4		
R-08	Vulnerabilidad crítica (CVSS 9.8) en el ERP sin parchear.	4	5	20		

Dibuja la matriz de riesgo 5×5 y sitúa cada riesgo

Completa la matriz de riesgo con los 8 riesgos anteriores. Escribe el número de riesgo (R-01 a R-08) en la celda correspondiente a su probabilidad e impacto. Colorea las celdas: verde=BAJO, amarillo=MEDIO, naranja=ALTO, rojo=CRÍTICO.

PVI →	1 (MB)	2 (B)	3 (M)	4 (A)	5 (MA)
5 (MA)					
4 (A)					

3 (M)					
2 (B)					
1 (MB)					

Leyenda: VERDE = BAJO (1-5) · AMARILLO = MEDIO (6-12) · NARANJA = ALTO (13-19) · ROJO = CRÍTICO (20-25)

ACT-07**Supuesto integrador — Plan de implantación inicial****Capacidad:** C1 / CE1.4 (COMPLETO) | **Tipo:** Individual | **Duración:** 90 min**Enunciado — GestiónSocial S.L.**

GestiónSocial S.L. es una empresa privada de 45 empleados que presta servicios de gestión de prestaciones sociales por encargo de varios ayuntamientos andaluces. Trata datos de colectivos vulnerables (personas en exclusión social, menores tutelados, familias con recursos económicos limitados). Sus sistemas principales son:

- **SIGEST:** aplicación web de gestión de expedientes sociales. Aloja datos de 12.000 beneficiarios. Acceso por 30 trabajadores sociales.
- **INFORME-DOC:** servidor de documentos con informes sociales, resoluciones y expedientes en PDF. 8 TB de datos históricos.
- **COMUN-AYTO:** plataforma de intercambio de información con los ayuntamientos clientes. Acceso por API REST.
- **ADMIN-RRHH:** sistema de nóminas y gestión de personal. Contiene datos de los 45 empleados.

La empresa quiere presentarse a la convocatoria de contratos del Servicio Andaluz de Empleo, que exige acreditación de adecuación al ENS. Además, la Agencia de Protección de Datos de Andalucía ha iniciado una inspección preventiva.

Tarea 1 — Identificación de sistemas y categoría ENS

Para cada sistema, determina la categoría ENS indicando la valoración de cada dimensión CIA y la dimensión determinante. Justifica específicamente por qué los datos tratados elevan o no la categoría.

Sistema	C	I	D	Dim. determinante	Categoría ENS	Justificación clave
SIGEST						
INFORME-DOC						
COMUN-AYTO						
ADMIN-RRHH						

Tarea 2 — Análisis de requisitos de seguridad (Anexo II ENS)

Para el sistema de mayor categoría, lista al menos 8 medidas de seguridad del Anexo II del RD 311/2022 que serían obligatorias. Indica para cada una si corresponde al marco [org], [op] o [mp] y si aplica a categoría Básica, Media o Alta.

Medida ENS (código + nombre)	Marco	Categoría mínima	Estado actual estimado
------------------------------	-------	------------------	------------------------

Tarea 3 — Obligaciones RGPD y formulario RAT

Cumplimenta el Registro de Actividades de Tratamiento (RAT) para el sistema SIGEST, con los datos disponibles en el enunciado. Completa todos los campos; si alguno requiere información adicional, indícalo explícitamente.

Campo RAT (art. 30 RGPD)	Contenido para SIGEST
1. Responsable del tratamiento	GestiónSocial S.L. — CIF: B-XXXXXXXXX Responsable: [completar] DPD/DPO: [indicar si aplica y por qué]
2. Finalidad del tratamiento	
3. Base jurídica del tratamiento	
4. Categorías de interesados	
5. Categorías de datos personales	
6. Destinatarios / encargados	
7. Transferencias internacionales	No aplica / [completar si aplica]
8. Plazos de conservación	
9. Medidas de seguridad (art. 32)	
10. ¿Requiere DPIA?	[Sí / No — justificar citando art. 35 RGPD]

Tarea 4 — Informe ejecutivo de recomendaciones

Redacta un informe ejecutivo breve (máximo 300 palabras) dirigido a la dirección de GestiónSocial S.L., en el que expliques: (1) los riesgos legales actuales, (2) las acciones prioritarias antes de presentarse a la licitación y (3) el plazo realista para obtener la adecuación al ENS. Usa un tono profesional apropiado para la dirección de una empresa.

